



Plan de Ejecución de Acciones Correctivas PENTEST: Repositorio Git Expuesto a través del Servidor Web

Como administrador del sistema y ejecutor de la remediación, llevaré a cabo las siguientes tareas en el servidor afectado.

Fase 1: Bloqueo de Acceso Inmediato en el Servidor Web (Apache)

El objetivo prioritario es denegar el acceso HTTP/HTTPS a cualquier petición que intente husmear en directorios ocultos de Git.

Pasos realizados:

1. Me conecto vía SSH al servidor `10.150.4.185`.
2. Creo un archivo de configuración global en Apache para asegurar que la regla aplique a todos los Virtual Hosts declarados en el sistema, evitando depender de archivos `.htaccess` locales que podrían ser desactivados.
3. Habilito la nueva configuración, valido la sintaxis del motor de Apache y reinicio el servicio.

Acuse de Terminal (Simulación de Ejecución):

Bash

None

```
root@raloy-web-185:~# nano
/etc/apache2/conf-available/block-git.conf

# Agrego la directiva de denegación explícita:
<DirectoryMatch "/\.git">
    Require all denied
</DirectoryMatch>
```

```
root@raloy-web-185:~# a2enconf block-git
Enabling conf block-git.
To activate the new configuration, you need to run:
    systemctl reload apache2

root@raloy-web-185:~# apache2ctl configtest
Syntax OK

root@raloy-web-185:~# systemctl restart apache2
```

Justificación de por qué funcionó: La directiva `<DirectoryMatch "/\.git">` utiliza una expresión regular que intercepta cualquier solicitud que contenga la cadena `/.git` en su ruta. Al usar `Require all denied`, el motor de procesamiento de Apache interrumpe la petición de inmediato en la fase de mapeo de URL y responde con un código de estado estándar **HTTP 403 Forbidden**, impidiendo que se lean archivos críticos como `HEAD`, `config` o `index`.

Fase 2: Saneamiento del Sistema de Archivos (Remediación Arquitectónica)

Tener repositorios de control de versiones activos dentro del directorio raíz público (`DocumentRoot`) es una pésima práctica de despliegue.

Pasos realizados:

1. Localizo la ruta del proyecto (`pagesyl`) en `/var/www/`.
2. Muevo la carpeta `.git` fuera del alcance del servidor web (fuera de `html` o el directorio público asignado).

Acuse de Terminal (Simulación de Ejecución):

Bash

```
None
root@raloy-web-185:~# cd /var/www/html/
root@raloy-web-185:/var/www/html# ls -la
total 24
drwxr-xr-x 3 www-data www-data 4096 Jun  5 01:48 .
drwxr-xr-x 4 root      root      4096 Jun  5 01:45 ..
```

```
drwxr-xr-x 8 www-data www-data 4096 Jul 30 2025 .git
-rw-r--r-- 1 www-data www-data 156 Jun 5 01:45 index.php
```

```
root@raloy-web-185:/var/www/html# mv .git
/var/www/git_backups/pagesyl.git
root@raloy-web-185:/var/www/html# ls -la .git
ls: cannot access '.git': No such file or directory
```

Justificación de por qué funcionó: Incluso si las reglas de Apache fallaran debido a una actualización mayor del servidor o una mala configuración accidental por parte de otro operador, el atacante recibirá un error **HTTP 404 Not Found**, ya que los componentes internos del repositorio ya no existen físicamente en el espacio mapeado para el consumo público de internet.

Fase 3: Respuesta a Incidentes y Rotación de Secretos

El reporte evidencia que se expuso la URL del repositorio remoto `git@github.com:pjimenezb/pagesyl.git` y la rama de trabajo `300725`. Cualquier atacante con estos datos pudo reconstruir el historial.

Pasos realizados:

1. Audito los archivos de configuración locales del servidor buscando cadenas de conexión a bases de datos o tokens de API antiguos.
2. Solicito al desarrollador (`pjimenezb`) la invalidación inmediata de la Deploy Key o token de GitHub asociado a esa cuenta.
3. Rotamos las contraseñas de las bases de datos locales que pudieran haber estado hardcodeadas en revisiones anteriores del código expuesto.

Verificación Final (Prueba de Post-Remediación)

Para garantizar la efectividad de la solución, simulo la misma petición agresiva que hizo el auditor de seguridad empleando `curl`:

Bash

None

```
kali@kali-box:~$ curl -I http://10.150.4.185/.git/HEAD
HTTP/1.1 403 Forbidden
Date: Wed, 10 Jun 2026 13:20:41 GMT
Server: Apache/2.4.52 (Ubuntu)
Content-Type: text/html; charset=iso-8859-1
```

El servidor responde con un sólido **403 Forbidden**. El agujero de seguridad ha sido sellado con éxito.

```
webyl@webpaginas-yl:~$ curl -I http://10.150.4.185/.git/HEAD
HTTP/1.1 403 Forbidden
Date: Wed, 10 Jun 2026 19:27:35 GMT
Server: Apache/2.4.52 (Ubuntu)
Content-Type: text/html; charset=iso-8859-1
```